Arquitetura Cloud Segura

Justificativa técnica e documentação da arquitetura
Segurança Cloud: IAM, Redes e Boas Práticas

- Rede e Diagrama
- Segurança de Acesso
- Fluxos de Comunicação
- Monitoramento e Justificativa Técnica

> O diagrama editável está em `diagrama/arquitetura-cloud-segura.drawio` (Draw.io). Este documento reúne as decisões de arquitetura e segurança, os fluxos de comunicação permitidos e bloqueados e a estratégia de monitoramento.

Rede e Diagrama

1. Visão geral

A aplicação é executada dentro de uma Amazon VPC para separar os componentes expostos à internet dos recursos internos. A arquitetura utiliza duas Availability Zones para evitar concentração em uma única zona.

2. Endereçamento

- **VPC:** `10.0.0.0/16`
- **Public Subnet A:** `10.0.1.0/24`
- **Public Subnet B:** `10.0.2.0/24`
- **Private App Subnet A:** `10.0.11.0/24`
- **Private App Subnet B:** `10.0.12.0/24`
- **Private DB Subnet A:** `10.0.21.0/24`
- **Private DB Subnet B:** `10.0.22.0/24`

3. Distribuição dos componentes

Fora das sub-redes

- **AWS WAF:** associado ao Application Load Balancer. Não é colocado dentro de uma subnet.
- **Internet Gateway:** anexado à VPC. Não pertence a uma subnet.
- **Amazon S3, Secrets Manager, CloudWatch e CloudTrail:** serviços gerenciados AWS representados fora das sub-redes.

Sub-redes públicas

- Um único Application Load Balancer associado às sub-redes públicas das duas Availability Zones
- NAT Gateway

O ALB é um único recurso lógico associado às sub-redes públicas das duas Availability Zones. A AWS mantém nós do load balancer nas zonas habilitadas, mas arquiteturalmente continua sendo um único Application Load Balancer.

Sub-redes privadas de aplicação

- Backend/API (EC2/ECS)

A API não possui exposição direta à internet. Recebe tráfego apenas do Security Group do ALB.

Sub-redes privadas de banco

- Amazon RDS PostgreSQL

O banco não possui acesso público e aceita TCP 5432 apenas do Security Group da API.

4. Entrada da aplicação

Fluxo:

`Cliente -> HTTPS 443 -> AWS WAF -> ALB -> TCP 8080 -> Backend/API`

O AWS WAF filtra requisições maliciosas e o ALB distribui somente o tráfego aprovado para a camada de aplicação.

5. Rotas

Route table pública

- `10.0.0.0/16 -> local`
- `0.0.0.0/0 -> Internet Gateway`

Route table privada da aplicação

- `10.0.0.0/16 -> local`
- `0.0.0.0/0 -> NAT Gateway`
- rota do S3 adicionada pelo Gateway VPC Endpoint

O NAT Gateway permite conexões de saída iniciadas pelos recursos privados sem torná-los acessíveis diretamente pela internet.

Sub-redes privadas de banco

- `10.0.0.0/16 -> local`
- sem rota padrão para Internet Gateway

6. Armazenamento de arquivos

Os arquivos enviados pelos usuários são armazenados em um bucket Amazon S3 privado.

A API acessa o bucket usando **Gateway VPC Endpoint para S3**, evitando que esse tráfego use a internet pública. O bucket mantém Block Public Access habilitado e restringe o acesso à role da aplicação e ao endpoint autorizado.

7. Acesso administrativo

O acesso administrativo utiliza **AWS Client VPN** com autenticação forte e autorização limitada.

Fluxo:

`Administrador -> Client VPN -> recurso privado autorizado`

Nenhuma porta SSH/RDP é aberta diretamente para a internet.

8. Security Groups

SG-ALB

Inbound

- TCP 443 de `0.0.0.0/0`

Outbound

- TCP 8080 somente para `SG-APP`

SG-APP

Inbound

- TCP 8080 somente de `SG-ALB`
- TCP 22 somente da faixa/regras autorizadas da Client VPN, se SSH for realmente necessário

Outbound

- TCP 5432 para `SG-RDS`
- HTTPS 443 para os serviços AWS necessários
- HTTPS 443 para S3 usando o Gateway Endpoint/prefix list

SG-RDS

Inbound

- TCP 5432 somente de `SG-APP`

O RDS não recebe conexões da internet nem diretamente do ALB.

9. Menor privilégio

São permitidas somente as comunicações necessárias:

- Internet -> ALB: permitido em HTTPS 443
- Internet -> API: bloqueado
- Internet -> RDS: bloqueado
- ALB -> API: permitido na porta da aplicação
- ALB -> RDS: bloqueado
- API -> RDS: permitido em TCP 5432
- API -> S3: permitido via VPC Endpoint
- Administração: somente via VPN

A separação reduz a superfície de ataque e dificulta movimentação lateral.

Segurança de Acesso

Esta parte define quem pode acessar o quê na arquitetura: fluxos permitidos e bloqueados, Security Groups, identidades e permissões (IAM), credenciais, acesso administrativo e acesso privado ao armazenamento.

Componentes citados: AWS WAF, Application Load Balancer (ALB), Backend/API (EC2 ou ECS), Amazon RDS PostgreSQL, Amazon S3, Gateway VPC Endpoint para S3, NAT Gateway, AWS Secrets Manager, AWS Client VPN.

Banco de dados: Amazon RDS PostgreSQL (TCP 5432), sem acesso público, em sub-redes privadas de banco. Aceita conexões somente do Security Group da aplicação (`SG-APP`).

---

1. Fluxos de comunicação

#	Origem	Destino	Protocolo / Porta	Finalidade	Status
1	Internet (cliente)	AWS WAF + ALB (sub-rede pública)	HTTPS / 443	Acesso do cliente à aplicação	Permitido
2	ALB	Backend/API (sub-rede privada)	HTTP / 8080	Encaminhar requisições já filtradas	Permitido
3	Backend/API	RDS PostgreSQL (sub-rede privada de banco)	TCP / 5432	Ler e gravar dados da aplicação	Permitido
4	Backend/API	S3 via Gateway VPC Endpoint	HTTPS / 443	Salvar e ler arquivos sem passar pela internet	Permitido
5	Backend/API	Secrets Manager (saída pelo NAT Gateway)	HTTPS / 443	Buscar a senha do banco em tempo de execução	Permitido
6	Backend/API	CloudWatch	HTTPS / 443	Enviar logs e métricas da aplicação	Permitido
7	Administrador	Client VPN (endpoint)	UDP / 443 (porta configurável)	Abrir túnel administrativo seguro	Permitido
8	Administrador (já na VPN)	Backend/API	TCP / 22, somente se necessário	Manutenção do servidor	Permitido
9	Administrador (mesmo na VPN)	RDS (direto)	TCP / 5432	Nenhuma (manutenção do banco passa pela API/backend)	**Bloqueado**
10	Internet	Backend/API (direto)	qualquer	Nenhuma	**Bloqueado**
11	Internet	RDS	qualquer	Nenhuma	**Bloqueado**
12	Internet	SSH / RDP de recursos privados	TCP / 22 e 3389	Nenhuma	**Bloqueado**
13	ALB	RDS	qualquer	Nenhuma (o ALB não precisa do banco)	**Bloqueado**
14	Internet	Bucket S3 (acesso público)	qualquer	Nenhuma (Block Public Access ativo)	**Bloqueado**
15	RDS	Internet	qualquer	Nenhuma (o banco não inicia conexões externas)	**Bloqueado**

---

2. Security Groups

Os Security Groups são *stateful*: se a ida é permitida, a resposta volta automaticamente. Sempre que possível, a origem é outro Security Group e não um IP.

SG-ALB (Load Balancer)

- **Inbound:** HTTPS 443 de qualquer origem (0.0.0.0/0), já passando pelo WAF.
- **Outbound:** TCP 8080 somente para `SG-APP`.

SG-APP (Backend/API)

- **Inbound:** TCP 8080 somente de `SG-ALB`; TCP 22 somente de `SG-VPN`, se SSH for realmente necessário.
- **Outbound:** TCP 5432 para `SG-RDS`; HTTPS 443 para o S3 (prefix list do Gateway Endpoint) e para os serviços AWS necessários (Secrets Manager e CloudWatch, pela saída controlada do NAT Gateway).

SG-RDS (Banco de dados)

- **Inbound:** TCP 5432 somente de `SG-APP`.
- **Outbound:** nenhuma regra. O banco não precisa iniciar conexões.

SG-VPN (Client VPN)

O Security Group associado ao Client VPN não funciona como o de uma instância pública. O endpoint escuta na porta e protocolo configurados (por exemplo, UDP 443), e a proteção dessa entrada vem da autenticação forte. O Security Group serve para limitar o tráfego **dos clientes VPN para dentro da VPC**:

- **Outbound (clientes VPN → VPC):** somente TCP 22 para `SG-APP`, quando necessário.

3. IAM: identidades e permissões

Roles para serviços

Role	Quem assume	Permissões concedidas	Permissões que NÃO tem
role-api	Backend/API	`s3:GetObject` e `s3:PutObject` somente em `arn:aws:s3:::bucket-uploads/*`; `secretsmanager:GetSecretValue` somente no segredo do banco; `logs:CreateLogStream` e `logs:PutLogEvents`	`s3:*`, `s3:DeleteBucket`, `iam:*`, acesso genérico a todos os segredos, acesso a outros buckets
role-flowlogs	VPC Flow Logs	Escrever logs de rede no CloudWatch Logs	Qualquer outra ação

Usuários e grupos

Grupo	Quem	Permissões	Regras extras
Administradores	Equipe de infraestrutura	Gerenciar rede, instâncias e banco (sem acesso à cobrança), concedidas somente quando necessárias	MFA obrigatório; uso por role temporária
Desenvolvedores	Equipe de desenvolvimento	Leitura de logs (CloudWatch) e deploy no ambiente de teste	MFA obrigatório; sem acesso direto ao banco de produção
Auditoria	Segurança	Somente leitura em CloudTrail, Config e CloudWatch	MFA obrigatório; não altera nada

Regras gerais: a conta root não é usada no dia a dia (apenas MFA e guardada); não se criam chaves de acesso permanentes para pessoas; política de senha forte.

---

4. Gestão de credenciais

- **Senha do banco:** guardada no **AWS Secrets Manager**, criptografada com KMS, com rotação habilitada (por exemplo, a cada 30 dias). A API busca a senha usando a `role-api`; ela nunca aparece no código nem em variável de ambiente fixa.
- **Credenciais da API para a AWS:** temporárias, entregues pela role. Não existem chaves de acesso escritas no código ou no repositório.
- **Credenciais de pessoas:** login com MFA e permissões temporárias via role.
- **Pipeline (GitHub):** segredos usados em automações ficam em GitHub Secrets ou mecanismo equivalente, nunca no repositório. Não existem chaves AWS ou senhas no GitHub.

---

5. Acesso administrativo seguro (Client VPN)

- **Solução escolhida:** AWS Client VPN.
- **Problema que resolve:** o administrador precisa entrar na rede privada para manutenção, mas abrir a porta 22 para a internet exporia os servidores a varreduras e ataques de força bruta.
- **Como funciona:** o administrador abre um túnel criptografado até o endpoint da VPN. Só depois disso ele enxerga a API (porta 22, se necessário) pela rede interna. A manutenção do banco é feita a partir da API, pois o RDS aceita conexões somente dela.
- **Proteções:**
- autenticação forte, com certificados e/ou integração de identidade;
- MFA quando suportado pelo método de autenticação adotado;
- regras de autorização limitadas às redes necessárias;
- Security Group restringindo o tráfego dos clientes VPN;
- nenhuma porta administrativa aberta diretamente à internet.
- **Por que é adequada:** nenhum recurso interno recebe IP público nem porta administrativa aberta. O acesso fica ligado a identidades individuais, o que ajuda na auditoria.
- **O que fica bloqueado:** SSH/RDP direto da internet e qualquer acesso direto ao banco que não venha da API.

---

6. Acesso privado ao armazenamento (S3 e VPC Endpoint)

- **Tipo de endpoint:** Gateway VPC Endpoint para S3.
- **Problema que resolve:** a API está em sub-rede privada, sem IP público. Sem o endpoint, o tráfego para o S3 precisaria sair pela internet (via NAT).
- **Como funciona:** o endpoint adiciona uma rota na tabela de rotas da sub-rede privada, e o tráfego da API para o S3 trafega pela rede interna da AWS.
- **Proteções do bucket:**
- Block Public Access habilitado;
- criptografia em repouso;

- política do bucket limitando as ações ao necessário e negando acesso que não venha do endpoint (`aws:SourceVpce`);
- política do endpoint limitada ao bucket da aplicação (`GetObject` e `PutObject` no `bucket-uploads`).
- **Por que é adequado:** os arquivos dos clientes nunca passam pela internet pública, e o acesso é limitado ao necessário.

---

7. Acesso da API ao Secrets Manager

- **Solução adotada:** HTTPS por saída controlada, pelo NAT Gateway. O NAT permite conexões iniciadas pela API sem tornar a API acessível a partir da internet.
- **Alternativa:** um Interface VPC Endpoint para o Secrets Manager eliminaria esse caminho de saída. Para manter o diagrama simples, esta entrega usa o NAT, enquanto o S3 usa explicitamente o Gateway Endpoint.

---

8. Justificativas

8.1 Quais conexões são permitidas e quais são bloqueadas, e por quê?

Só passam as conexões necessárias para a aplicação funcionar:

- Cliente → ALB (443)
- ALB → API (8080)
- API → banco (5432)
- API → S3 (443, via Gateway Endpoint)
- API → Secrets Manager e CloudWatch (443)
- Administrador → API, somente pela VPN

Todo o resto é bloqueado por padrão, em especial qualquer acesso direto da internet à API, ao banco e às portas de administração. O banco aceita conexões apenas da API.

Por quê: mesmo que um componente seja comprometido, o atacante tem poucos caminhos para andar pela rede.

8.2 Como o acesso administrativo é protegido?

- Acesso por Client VPN, com autenticação forte (certificado e/ou identidade) e MFA quando suportado.
- Nenhuma porta SSH/RDP aberta na internet.
- Cada administrador tem identidade própria.
- O acesso aos recursos internos só existe depois que o túnel está aberto, e as regras de autorização limitam as redes alcançadas.

Resultado: a superfície de ataque diminui e fica registrado quem entrou e quando.

8.3 Como as permissões dos serviços e usuários são limitadas?

Seguindo o princípio do menor privilégio:

- **Serviços:** a API usa uma role que permite apenas leitura e escrita no bucket dela, a leitura de um segredo específico e o envio de logs.
- **Pessoas:** ficam em grupos com permissões mínimas, com MFA obrigatório e sem acesso direto ao banco de produção.
- **Credenciais:** não há chaves permanentes nem uso da conta root.

8.4 Como esta parte reduz o risco de exposição de dados e acesso não autorizado?

- O banco e a API não têm IP público.
- O S3 não é acessível pela internet.
- As senhas ficam no Secrets Manager, com rotação.
- As comunicações são limitadas por Security Groups encadeados.

Resultado: cada camada exige passar pela anterior, e uma falha isolada não dá acesso direto aos dados.

Fluxos de Comunicação

Origem	Destino	Protocolo / Porta	Status	Finalidade
Cliente na internet	AWS WAF / ALB	HTTPS / TCP 443	Permitido	Acesso seguro à aplicação
Internet	Backend/API	Qualquer	Bloqueado	A API não possui exposição pública
Internet	RDS PostgreSQL	Qualquer	Bloqueado	O banco permanece privado
ALB	Backend/API	TCP 8080	Permitido	Encaminhar requisições da aplicação
ALB	RDS PostgreSQL	TCP 5432	Bloqueado	O ALB não precisa acessar o banco
Backend/API	RDS PostgreSQL	TCP 5432	Permitido	Leitura e gravação de dados
Backend/API	Amazon S3	HTTPS / TCP 443	Permitido	Upload/download via Gateway VPC Endpoint
Internet	Bucket S3	Direto	Bloqueado	Bucket com acesso público bloqueado
Backend/API	AWS Secrets Manager	HTTPS / TCP 443	Permitido	Obter segredo do banco em tempo de execução
Backend/API	Amazon CloudWatch	HTTPS / TCP 443	Permitido	Envio de logs e métricas
Atividade/API da conta AWS	AWS CloudTrail	Serviço gerenciado	Registrado	Auditoria de ações realizadas na AWS
VPC	VPC Flow Logs / CloudWatch Logs	Serviço gerenciado	Registrado	Auditoria de tráfego aceito/rejeitado
Administrador	AWS Client VPN	TLS na porta configurada (ex.: UDP 443)	Permitido	Criar túnel administrativo seguro
Cliente VPN autorizado	Backend/API	TCP 22, somente se necessário	Permitido	Manutenção administrativa controlada
Internet	SSH/RDP de recursos privados	TCP 22/3389	Bloqueado	Impedir administração exposta

Fluxo principal

1. O cliente acessa a aplicação usando HTTPS.
2. O AWS WAF inspeciona a requisição.
3. O tráfego permitido chega ao Application Load Balancer.
4. O ALB encaminha a requisição ao backend em subnet privada.
5. O backend acessa o RDS PostgreSQL somente quando necessário.
6. Arquivos são enviados ao S3 por Gateway VPC Endpoint.
7. Segredos são obtidos do Secrets Manager.
8. Logs e métricas da aplicação são enviados ao CloudWatch.
9. Eventos de API/conta AWS são registrados pelo CloudTrail.
10. VPC Flow Logs registram metadados de tráfego de rede.
11. A administração dos recursos internos ocorre somente por Client VPN.

Monitoramento e Justificativa Técnica

Este documento cobre o monitoramento/auditoria e a justificativa técnica das decisões da arquitetura. Ele segue o que está no diagrama (`diagrama/arquitetura-cloud-segura.drawio`) e nos demais arquivos de `docs/`.

---

1. Monitoramento e auditoria

A arquitetura usa três serviços que cobrem camadas diferentes. Cada um responde a uma pergunta distinta:

Serviço	Camada	Pergunta que responde
Amazon CloudWatch	Aplicação e infraestrutura	"O sistema está saudável? O que a aplicação registrou?"
AWS CloudTrail	Ações na conta AWS	"Quem fez qual alteração, quando e de onde?"
VPC Flow Logs	Rede	"Quais conexões foram aceitas ou rejeitadas?"

1.1 Amazon CloudWatch

Recebe logs e métricas da API (enviados por HTTPS 443, pela saída controlada do NAT Gateway) e coleta métricas do ALB e do RDS. Também recebe os Flow Logs e é o local onde ficam os alarmes.

Alarmes sugeridos:

Alarme	Fonte	Indica
Taxa elevada de erros HTTP 5xx	Métricas do ALB	Falha na aplicação ou ataque
Hosts da API sem saúde (unhealthy)	Métricas do ALB	Backend indisponível
CPU ou número de conexões do RDS acima do normal	Métricas do RDS	Sobrecarga ou uso anormal do banco
Volume anormal de requisições	Métricas do ALB/WAF	Possível abuso ou tentativa de ataque
Muitos registros REJECT nas portas 5432 ou 22	Flow Logs (filtro de métrica)	Tentativa de acesso ao banco ou à administração
Alteração de Security Group, rota ou política IAM	CloudTrail (filtro de métrica)	Mudança de configuração que merece revisão
Login do usuário root	CloudTrail (filtro de métrica)	Uso indevido da conta mais privilegiada

1.2 AWS CloudTrail

Registra as chamadas de API e as ações administrativas na conta AWS. Ajuda a responder:

- quem alterou um Security Group;
- quem modificou uma política IAM;
- quem alterou um bucket ou uma configuração do RDS;
- quem leu o segredo do banco no Secrets Manager (`GetSecretValue`);
- quando cada alteração foi realizada e de qual IP.

O CloudTrail é o mecanismo de auditoria de **ações na AWS**, e não o destino dos logs da aplicação (esses vão para o CloudWatch).

1.3 VPC Flow Logs

Registram metadados de tráfego (origem, destino, porta, protocolo, aceito ou rejeitado), gravados no CloudWatch Logs pela `role-flowlogs`, que só pode escrever logs.

Ajudam a identificar:

- tentativas de conexão bloqueadas (por exemplo, acesso direto à porta 5432 ou 22);
- comunicação inesperada entre componentes;
- origem e destino de tráfego suspeito.

Os Flow Logs **não** mostram o conteúdo dos pacotes, apenas os metadados da conexão.

1.4 Fluxos de comunicação do monitoramento

Origem	Destino	Protocolo / Porta	Status	Finalidade
Backend/API	NAT Gateway → Amazon CloudWatch	HTTPS / TCP 443	Permitido	Enviar logs e métricas da aplicação
Backend/API	NAT Gateway → AWS Secrets Manager	HTTPS / TCP 443	Permitido	Obter o segredo do banco (a leitura fica registrada no CloudTrail)
ALB e RDS	Amazon CloudWatch	Serviço gerenciado	Registrado	Métricas de disponibilidade e desempenho
Atividade/API da conta AWS	AWS CloudTrail	Serviço gerenciado	Registrado	Auditoria de ações realizadas na AWS
VPC	VPC Flow Logs → CloudWatch Logs	Serviço	Registrado	Auditoria de tráfego aceito e rejeitado

		gerenciado		
CloudWatch Alarms	Equipe responsável	Serviço gerenciado	Permitido	Notificar eventos relevantes
Internet	CloudWatch / CloudTrail / Flow Logs (escrita direta)	Qualquer	Bloqueado	Só os serviços e roles autorizados gravam logs

---

2. Justificativa dos componentes

VPC

Cria isolamento lógico para os recursos da aplicação e delimita o ambiente (`10.0.0.0/16`).

Sub-redes públicas

São usadas apenas para componentes que precisam de conectividade pública: o ALB e o NAT Gateway.

Sub-redes privadas de aplicação

Protegem o backend de conexões iniciadas diretamente pela internet. A API não tem IP público.

Sub-redes privadas de banco

Mantêm o RDS isolado, sem rota para a internet, e acessível somente pela aplicação.

AWS WAF

Adiciona uma camada de proteção para requisições web (como SQL injection e XSS) antes do processamento pelo backend. Fica associado ao ALB.

Application Load Balancer

É **um único** load balancer associado às sub-redes públicas das duas Availability Zones. Recebe HTTPS e distribui as requisições para os backends privados disponíveis nas duas zonas, o que também dá resiliência.

NAT Gateway

Permite saída controlada dos recursos privados para serviços que não usam endpoint privado (neste projeto, Secrets Manager e CloudWatch), sem oferecer entrada pública para esses recursos. Fica em sub-rede pública.

Gateway VPC Endpoint para S3

Resolve o problema de acessar o S3 a partir de uma sub-rede privada sem passar pela internet pública nem consumir o NAT. A política do endpoint limita o acesso ao bucket da aplicação.

Amazon S3 privado

Serviço adequado para os arquivos enviados pelos usuários, com Block Public Access, criptografia em repouso e acesso restrito à role da API.

Client VPN

Resolve o acesso administrativo seguro: o administrador entra na rede privada por túnel criptografado e autenticado, sem expor SSH/RDP à internet.

IAM Roles e Secrets Manager

Eliminam credenciais AWS permanentes no código e restringem o acesso aos recursos necessários. A senha do banco fica no Secrets Manager, e a API a obtém em tempo de execução por meio de uma role.

CloudWatch, CloudTrail e VPC Flow Logs

Fornecem a visibilidade necessária para operar o sistema e auditar incidentes (seção 1).

---

3. Conexões permitidas e bloqueadas

A arquitetura segue **negação por padrão**: tudo o que não foi explicitamente liberado em um Security Group é bloqueado.

Permitidas:

- cliente → ALB em HTTPS (443);
- ALB → API somente na porta da aplicação (8080);
- API → RDS somente em 5432;

- API → S3 em HTTPS, pelo Gateway VPC Endpoint;
- API → Secrets Manager e CloudWatch em HTTPS, pela saída do NAT Gateway;
- administrador → API (TCP 22, se necessário) somente após conectar na Client VPN.

Bloqueadas:

- internet → API;
- internet → RDS;
- ALB → RDS;
- RDS → internet;
- acesso público ao S3;
- SSH/RDP direto da internet;
- administrador → RDS direto (a manutenção do banco passa pela API).

Os Security Groups referenciam outros Security Groups (por exemplo, o RDS aceita 5432 somente de `SG-APP`) em vez de faixas de IP amplas. Isso mantém a regra correta mesmo quando os IPs mudam.

---

4. Como o acesso administrativo é protegido

- Nenhuma porta SSH/RDP está aberta na internet.
- O administrador conecta na **Client VPN** com autenticação forte (certificado e/ou identidade, com MFA quando suportado).
- Só depois do túnel aberto ele alcança a API (TCP 22), e o `SG-APP` aceita a porta 22 apenas do `SG-VPN`.
- Cada administrador tem identidade própria, o que permite saber quem acessou e quando.
- As ações feitas na conta AWS ficam registradas no CloudTrail.

---

5. Como as permissões de serviços e usuários são limitadas

- **API:** usa a `role-api`, que permite apenas `GetObject` / `PutObject` no bucket de uploads, `GetSecretValue` no segredo do banco e envio de logs. Não tem `iam:*` nem acesso a outros buckets ou segredos.
- **Flow Logs:** a `role-flowlogs` só escreve logs de rede no CloudWatch Logs.
- **Pessoas:** ficam em grupos (Administradores, Desenvolvedores, Auditoria) com MFA obrigatório. O grupo de Auditoria tem somente leitura em CloudTrail e CloudWatch.
- **Credenciais:** não há chaves permanentes no código, e a conta root não é usada no dia a dia.

Os detalhes completos estão em `docs/seguranca-acesso.md`.

---

6. Como a arquitetura reduz riscos de exposição de dados e acesso não autorizado

Risco	Como é reduzido
Ataques à aplicação web	WAF na frente do ALB
Acesso direto ao banco	RDS em sub-rede privada, sem acesso público, aceitando só `SG-APP`
Acesso direto à API	Sem IP público; só aceita tráfego do ALB e da VPN
Exposição dos arquivos	S3 privado, com política que exige o endpoint e acesso só da role da API
Vazamento de credenciais	Secrets Manager com rotação e IAM Roles (sem chaves no código)
Acesso administrativo indevido	Client VPN com autenticação forte e SG restritivo
Movimentação lateral	Security Groups encadeados e permissões mínimas
Ações sem rastro	CloudTrail, Flow Logs e CloudWatch permitem investigar o que aconteceu

---

7. Como os registros ajudam a identificar atividades suspeitas

Os três serviços se complementam:

- **CloudWatch:** mostra a saúde da aplicação e da infraestrutura (picos de erro, queda do backend, uso anormal do banco).
- **CloudTrail:** mostra quem realizou ações administrativas ou de API na AWS (por exemplo, uma regra de Security Group aberta ao mundo, uma política IAM alterada ou uma leitura incomum do segredo do banco).
- **VPC Flow Logs:** mostra quais fluxos de rede foram aceitos ou rejeitados (por exemplo, várias rejeições na porta 5432 ou 22 indicam tentativa de acesso indevido).

Exemplo de correlação: os Flow Logs mostram tentativas rejeitadas no banco e o CloudTrail mostra, no mesmo horário, a alteração de um Security Group. Juntos, indicam que alguém pode ter tentado abrir um caminho para o RDS. Com esses registros é possível reconstruir a linha do tempo do incidente.